

Practical 4: Rate Limiting Control Assessment

Objective

To evaluate whether the application's account registration functionality implemented adequate rate limiting and request control mechanisms to prevent automated or bulk account creation.

Tools Used

- Burp Suite
- Mozilla Firefox
- Internshala Ethical Hacking Practice Lab

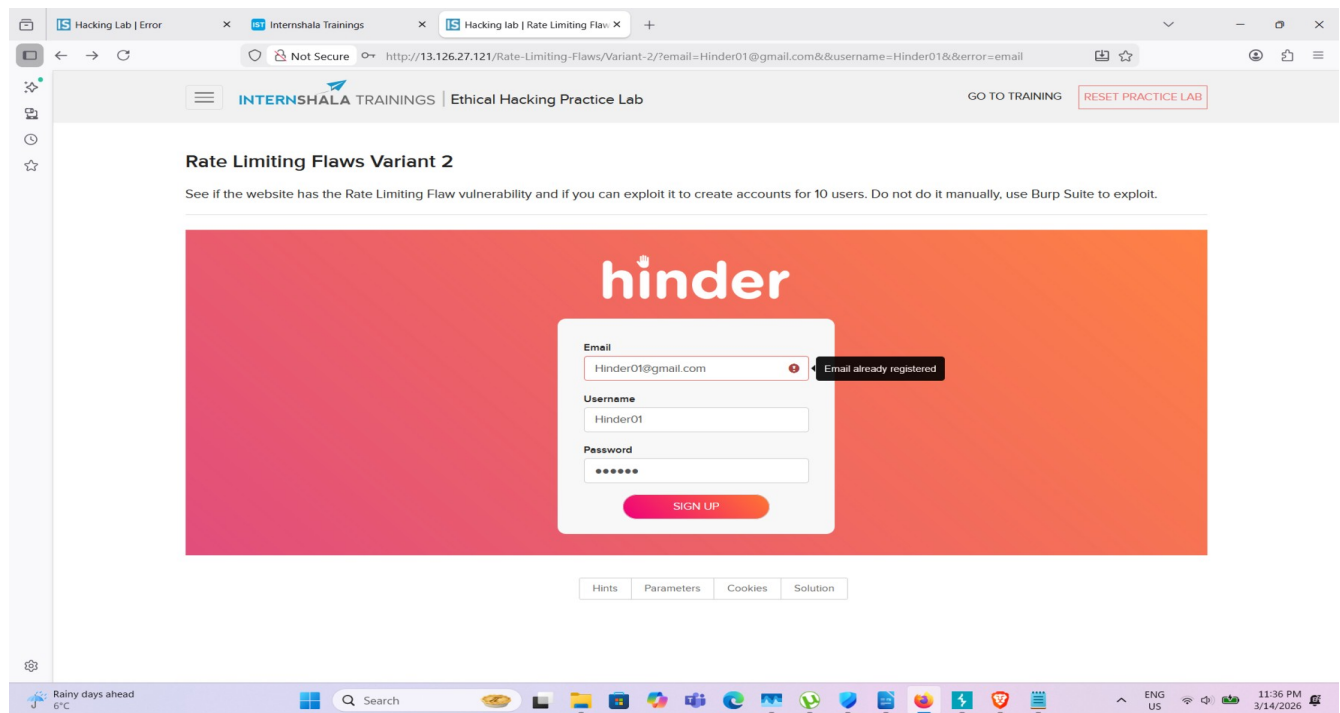
Target Application

The assessment was performed against the user registration feature of a training web application to determine whether multiple account creation requests could be automated and processed without restriction.

Methodology

Step 1: Registration Page Analysis

The account registration functionality was reviewed to understand the registration workflow and identify the parameters required for account creation.



Step 2: Email Payload Configuration

The registration request was intercepted using Burp Suite and sent to Intruder. The Pitchfork attack type was configured, and multiple email address payloads were prepared for automated testing.

The screenshot shows the Burp Suite Intruder interface with a Pitchfork attack configured. The target is `http://13.126.27.121`. The attack is set to "Pitchfork attack" with "Start attack" button. The payload positions are 1, 2, 3, 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16. The payload configuration is set to "Simple list" with a payload count of 10 and a request count of 10. The payload list includes email addresses like `Hinder01@gmail.com`, `Hinder02@gmail.com`, `Hinder03@gmail.com`, `Hinder04@gmail.com`, `Hinder05@gmail.com`, `Hinder06@gmail.com`, `Hinder07@gmail.com`, `Hinder08@gmail.com`, `Hinder09@gmail.com`, and `Hinder10@gmail.com`. The payload processing section is empty, and the payload encoding is set to "Disabled".

Step 3: Username Payload Configuration

Additional username payloads were configured within Burp Suite Intruder using the Pitchfork attack mode to simulate multiple account registrations with unique user details.

The screenshot shows the Burp Suite Intruder interface with a Pitchfork attack configured. The target is `http://13.126.27.121`. The attack is set to "Pitchfork attack" with "Start attack" button. The payload positions are 1, 2, 3, 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16. The payload configuration is set to "Simple list" with a payload count of 10 and a request count of 10. The payload list includes usernames like `Hinder01`, `Hinder02`, `Hinder03`, `Hinder04`, `Hinder05`, `Hinder06`, `Hinder07`, `Hinder08`, `Hinder09`, and `Hinder10`. The payload processing section is empty, and the payload encoding is set to "Disabled".

Step 4: Automated Request Execution

The attack was executed, allowing multiple registration requests to be processed automatically using the configured payload sets. The application accepted the requests without enforcing sufficient rate limiting or registration controls.

The screenshot shows the Burp Suite interface during an intruder attack. The top bar indicates the target is '4. Intruder attack of http://13.126.27.121'. The 'Results' tab is active, showing a list of requests and responses. The selected request is a POST to '/Rate-Limiting-Flaws/Variant-2/register.php' with a payload of 'Hinder11@gmail.com'. The response is a 302 status code, indicating a redirect. The 'Inspector' tab on the right shows the raw response data, including headers like 'Server: nginx/1.14.0 (Ubuntu)' and 'Date: Sat, 14 Mar 2026 23:40:32 GMT'.

Step 5: Verification of Created Accounts

The registration page was revisited to verify the outcome of the automated requests. The application indicated that the submitted accounts had already been created, confirming successful registration processing.

The screenshot shows the Hinder application's registration page. The page has a header with 'INTERNSHALA TRAININGS | Ethical Hacking Practice Lab' and a 'GO TO TRAINING' button. The main heading is 'Rate Limiting Flaws Variant 2'. Below the heading, there is a message: 'See if the website has the Rate Limiting Flaw vulnerability and if you can exploit it to create accounts for 10 users. Do not do it manually, use Burp Suite to exploit.' The registration form has three fields: 'Email' (with a red error message 'Email already registered'), 'Username' (with the value 'Hinder11'), and 'Password'. A 'SIGN UP' button is at the bottom of the form. The page also includes a footer with 'Hints', 'Parameters', 'Cookies', and 'Solution' links.

Result

The application processed multiple account registration requests within a short period without enforcing effective rate limiting or abuse-prevention controls. This behavior demonstrates a weakness in request throttling and automated account creation protection.

Security Impact

Insufficient rate limiting may allow attackers to automate account creation, resource abuse, spam registrations, and large-scale exploitation of application functionality. Proper controls should be implemented to detect and restrict excessive requests.

Recommended Mitigations

- Implement rate limiting for registration endpoints.
- Introduce CAPTCHA or challenge-response mechanisms.
- Apply account creation thresholds per IP address.
- Monitor and alert on unusual registration activity.
- Use bot detection and automated abuse prevention controls.

Learning Outcome

This practical exercise provided experience in assessing application resilience against automated requests and demonstrated the importance of rate limiting mechanisms in preventing abuse of web application functionality.